深信服应用交付虚拟化产品 vAD

技术白皮书

深信服科技有限公司

www.sangfor.com

目录

目录 2
一、 概述 4
二、 虚拟化平台部署说明 4
三、 vAD 配置管理 4
四、 vAD 产品详细说明 5
4.1 产品设计理念 5
4.2 多链路负载均衡 5
4.2.1 出站流量负载均衡 6
4.2.2 入站流量负载均衡 7
4.3 服务器负载均衡 9
4.3.1 NAT 方式 L4 服务器负载均衡 10
4.3.2 DR 方式 L4 服务器负载均衡 12
4.3.3 L7 服务器负载均衡 13
4.4 服务器性能优化 15
4.4.1 TCP 连接复用 15
4.4.2 内存缓存 16
4.4.3 HTTP 压缩 17
4.4.4 SSL 卸载 18
4.4.5 TCP 单边加速 19

4.4.6 服务器弹性负载.....20

4.4.7 数据库中间件等后台应用组件深入分析.....21

4.4.8 被动漏洞扫描.....23

五、 关于深信服.....25

一、 概述

深信服应用交付虚拟化产品，以下简称 vAD，是为了满足当前日益增长的数据中心和服务器虚拟化而推出的一款更易于在虚拟化环境部署、更好的针对虚拟化网络环境下的业务系统进行负载和优化的应用交付产品。

使用 vAD 无需购买硬件设备，更加易于部署在虚拟化网络环境中，且有效解决了硬件设备无法对虚拟网络环境下的业务系统进行更有针对性的负载和优化的问题。

二、 虚拟化平台部署说明

vAD是传统AD硬件设备的软件形态产品，它可以很好的适应客户的云计算环境，支持部署在VMware、KVM、Xen和Hyper-V等主流虚拟化平台中。

以下介绍以VMware平台为例。它基于VMware ESXi 5.5进行开发和测试，支持部署在VMware ESXi 5.0以上版本的虚拟环境中，部署vAD的VMware主机至少需要有40G硬盘空间剩余。

vAD 提供一个用于在 VMware 部署的 OVA 模板，可以通过 VMware 管理平台“部署 OVF 模板...”部署到 VMware 虚拟环境中。部署 vAD 需要配合部署一个授权服务器的虚拟主机，授权服务器使用 USB KEY 给 vAD 进行相关功能的授权。

vAD 不对 VMware 的虚拟机配置和操作（如克隆、快照、迁移等）进行限制，管理员可以通过 VMware 的这些常用操作对 vAD 的部署和配置进行简易灵活的修改。

三、 vAD 配置管理

1. 管理员可以通过 VMware 管理界面的控制台进行管理 IP/网关的配置，也可以查看 vAD 基本的网络配置(如路由、ARP、IP 等)和进行网络互通的测试(如 ping、traceroute)。

2. 管理员通过 VMware 给 vAD 设置的管理 IP，使用浏览器访问 vAD 的管理控制台，可以对 vAD 的网络、部署方式、优化策略等进行专业化的配置。

四、 vAD 产品详细说明

4.1 产品设计理念

应用交付产品提供非常丰富的优化功能，可以改善用户的业务应用性能与安全性，但是国内用户在实际使用中还是以传统负载均衡的方面居多。然而在中国乃至整个亚洲市场，在线上业务和电子商务等方面都逐渐涌现出更复杂的应用交付需求，这对发布业务应用的服务商而言也意味着将面临更多的挑战。与欧美发达国家相比，国内在宽带普及率和线路质量等方面都还存在一定的差距，因此用户访问体验还存在很大的优化空间。换言之，应用交付层面的种种性能优化特性，在这种环境中会愈加地凸显出来，甚至被一定程度地放大。

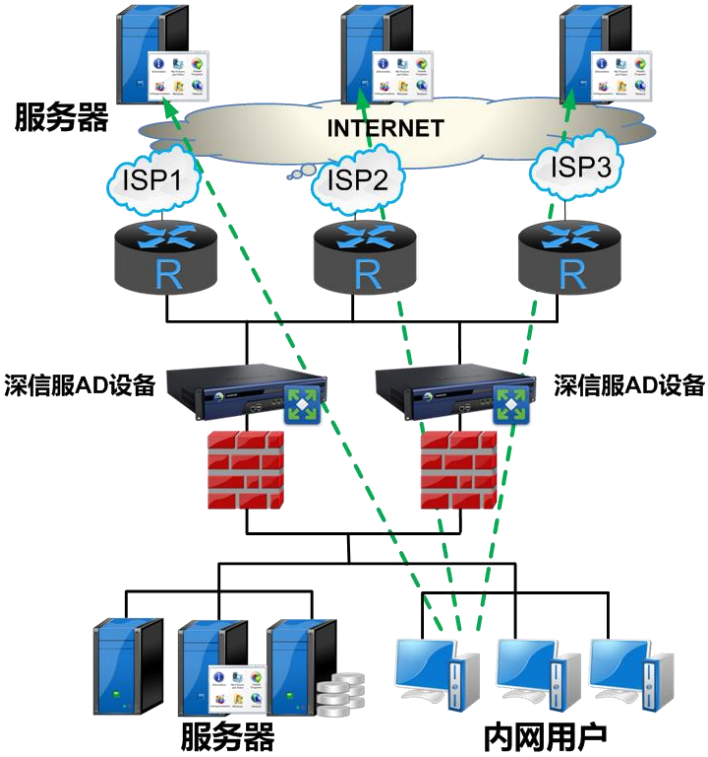
应用交付技术发展至今已经十分成熟，各厂商的产品之间基本上都是大同小异，只是侧重点有所不同；有的走得是集中方案，有的强调整合，有的偏重于安全；而深信服致力于提供快速、智能的应用交付解决方案，在众多功能细节中都体现了深信服对于不同地域、不同用户群市场需求的深刻理解，旨在让客户能获得超出业界同类产品的投资回报，在改善用户访问体验的同时，提升自身的业务竞争力。

4.2 多链路负载均衡

深信服 AD 应用交付设备集合出入站智能 DNS 解析、轮询、加权轮询、静态就近性、动态就近性等算法，解决多链路网络环境中流量分担的问题，充分提高多链路的带宽利用率，节约企事业单位对通信链路的投资；并且通过为用户分配最佳的通信线路，使用户获得绝佳的访问体验。此外，深信服 AD 应用交付设备还利用链路健康检查及会话保持技术，实现了在某条链路中断的情况下任然可以提供访问链接能力，充分利用了多条链路带来的可靠性保障，使对于用户的访问达到了最全面的支持。

4.2.1 出站流量负载均衡

内网的用户访问互联网访问资源时，深信服 AD 接收到用户的访问流量后，通过预先设定链路负载策略将用户访问流量分配到不同的互联网链路之上，实现出站流量负载均衡，提升互联网链路带宽利用率。

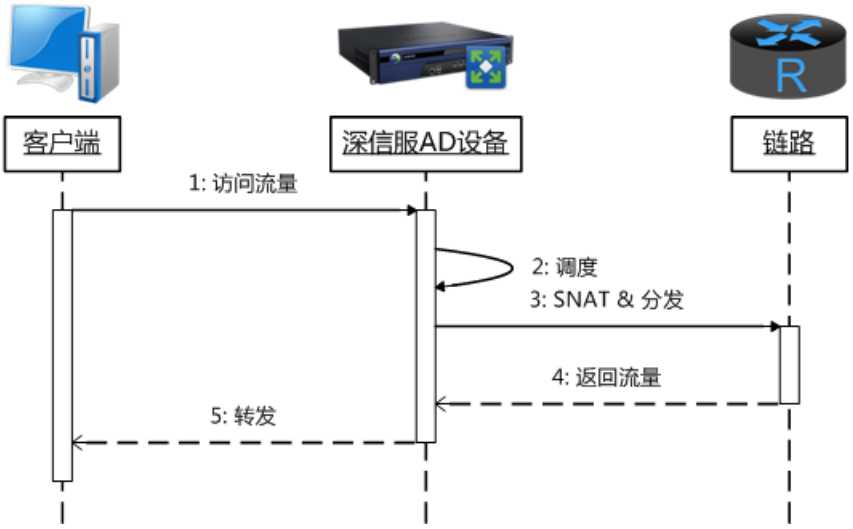


1. 实现方式

深信服 AD 接收到内网用户访问的流量以后，根据预先设定负载策略将访问电信的资源的出站流量分配到电信的链路之上，并做源地址的 NAT，（指定某一合法 IP 地址进行源地址的 NAT，或者用 AD 设备的接口地址自动映射），保证数据包返回时能够正确接收；同理，其它的访问的流量会通过相应策略会被分配到其它的运营商链路之上。

2. 工作流程

出站流量负载均衡的工作流程如下图所示

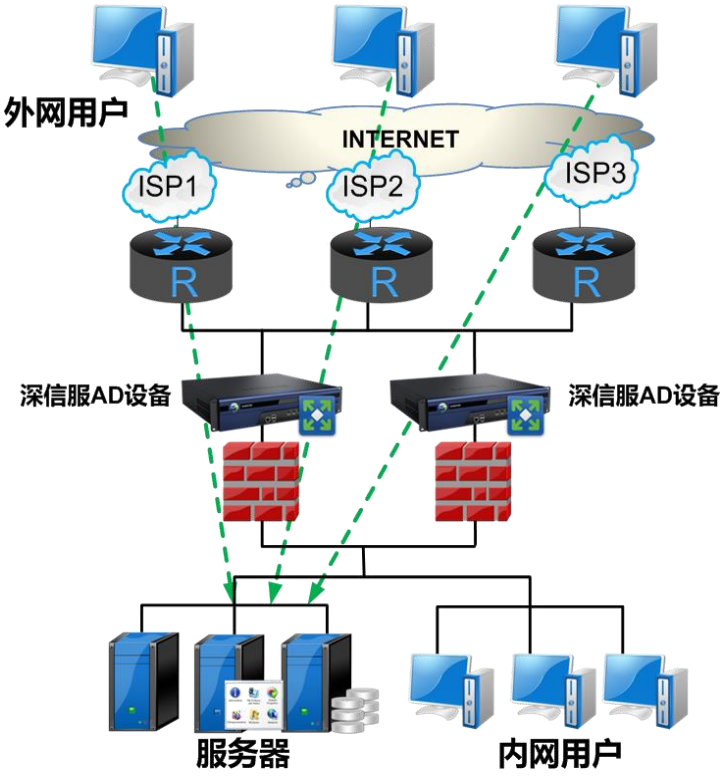


出站流量负载均衡的流程描述如下

步骤	说明
1	深信服 AD 设备收到来自内网用户的访问流量
2	深信服 AD 设备根据预先定义的负载均衡策略来选择出合适的出站链路
3	深信服 AD 设备按照链路选择的结果将流量分配给选定的出站链路，并做源地址的 NAT
4	深信服 AD 设备收到从外网返回的应答流量
5	深信服 AD 设备将流量转发给内网用户

4.2.2 入站流量负载均衡

当外部用户访问内部资源时，深信服 AD 通过智能 DNS 解析技术将一个域名绑定多个运营商的公网地址，负责解析来自不同运营商用户的域名解析请求；深信服 AD 根据不同负载均衡策略为不同运营商的用户返回最佳的访问地址，实现用户入站流量的负载均衡。



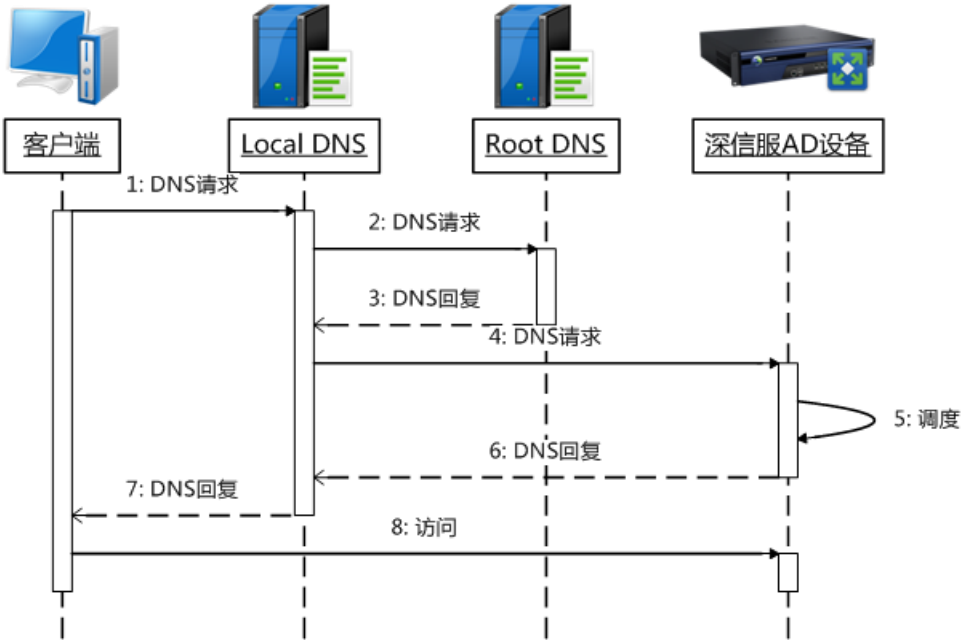
1. 实现方式

通过在域名注册提供商处修改域名 NS 记录，深信服 AD 设备获得域名解析权，深信服实现一个域名绑定多个运营商的公网地址，负责解析来自多个运营商用户的域名解析请求。

根据实现设定负载策略可以实现，如电信的用户通过电信的线路访问内部资源，联通的用户通过联通的线路访问内部资源；深信服 AD 还可以通过两条链路做反向查询，根据 RTT 时间判断链路的好坏，并且综合以上两个参数返回相应的 IP 地址。

2. 工作流程

入站流量负载均衡的工作流程如下图所示



入站流量负载均衡的流程描述如下

步骤	说明
1	外网用户的访问客户端向其本地 DNS 服务器发出域名解析请求
2	本地 DNS 服务器首先在本地搜索是否有相应的记录，如果没有就向根 DNS 服务器发起查询
3	根 DNS 服务器反馈本地 DNS 服务器，告知域名解析权授予深信服 AD 设备
4	本地 DNS 服务器会再次向深信服 AD 设备发出域名解析请求
5	深信服 AD 设备先判断链路的健康状况，再根据预先定义的负载均衡算法来选择出合适的 IP 地址作为域名解析结果
6	深信服 AD 设备将域名解析结果反馈给本地 DNS 服务器
7	本地 DNS 服务器将得到的域名解析结果转发给客户端
8	客户端根据得到的 IP 地址发起连接请求，对内网服务器进行访问

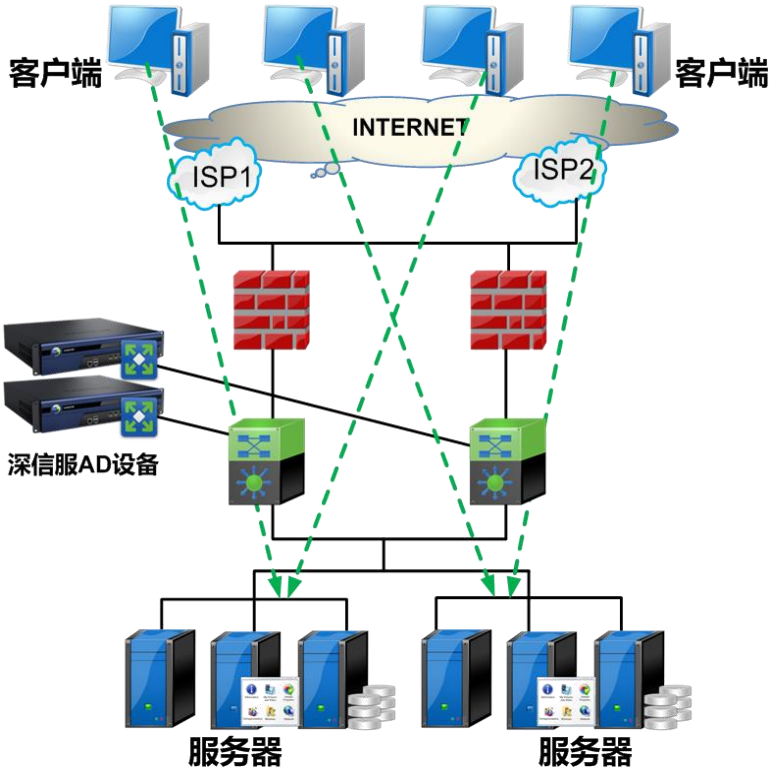
4.3 服务器负载均衡

运用多台服务器集群的机制，深信服 AD 应用交付设备能将所有真实服务器配置成虚拟服务来实现负载均衡，对外直接发布一个虚拟服务 IP。当用户请求到达应用交付设备的时候，根据预先设定的基于多重四、七层负载均衡算法的调度策略，能够合理的将每个连

接快速的分配到相应的服务器，从而合理利用服务器资源。不仅在减少硬件投资成本情况下解决单台服务器性能瓶颈，同时方便后续扩容，为大并发访问量的系统提供性能保障。

通过对服务器健康状况的全面监控，深信服 AD 应用交付设备能实时地发现故障服务器，并及时将用户的访问请求切换到其他正常服务器之上，实现多台服务器之间冗余。从而保证关键应用系统的稳定性，不会由于某台服务器故障，造成应用系统的局部访问中断。

近年来随着IPv4地址的逐渐枯竭，以及IPv6对安全性和可靠性的增强，很多用户的网络正在逐渐向IPv6过渡。为了适应这种趋势，深信服AD应用交付设备不仅能对IPv4协议的应用系统进行负载均衡，也同样支持基于IPv6 协议的L4/L7服务器负载均衡，以实现用户对 IPv6 服务的发布。



4.3.1 NAT 方式 L4 服务器负载均衡

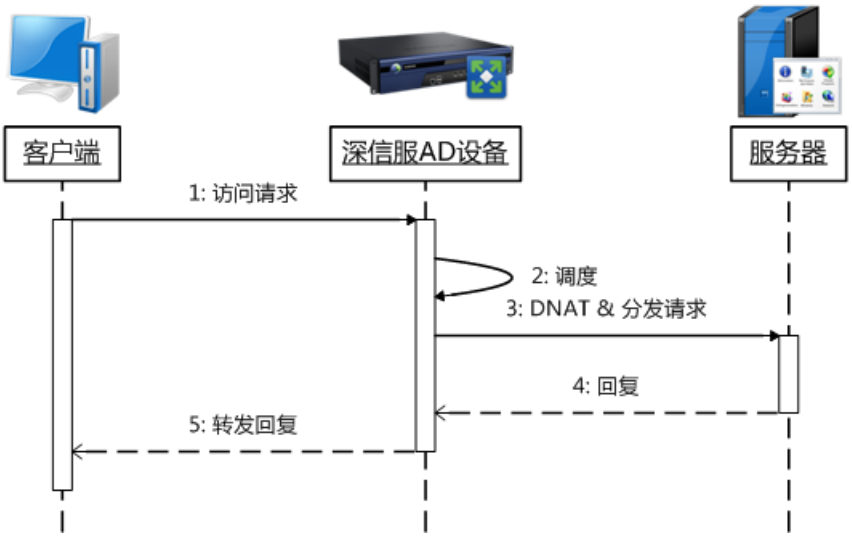
1. 实现方式

深信服 AD 设备支持基于 IP 地址、应用类型和内容等因素实现流量负载。通过这种方式管理员可以为不同类型的应用类型分配不同的服务器资源。应用类型调度支持基于不

同协议上的多种应用，包括 TCP、UDP、IP、DNS、E-mail、FTP、HTTP、RADIUS 等等。在实现 L4 服务器负载均衡的场景中，AD 设备负责将客户端的请求转发给服务器，然后客户端与服务器之间建立 TCP 连接，此时 AD 设备所扮演的角色类似于一台路由器。在 NAT 方式下，AD 设备调度访问请求时，先进行目的 IP 地址转换，再将访问请求转发给后端的每台服务器。

2. 工作流程

NAT 方式 L4 服务器负载均衡的工作流程如下图所示



NAT 方式 L4 服务器负载均衡的流程描述如下

步骤	说明
1	客户端发送服务访问请求，此时的源 IP 为客户端 IP、目的 IP 为虚拟服务 IP
2	深信服 AD 设备接收到访问请求后，根据预先定义的负载均衡调度算法判断出应该将访问请求分发给哪台服务器
3	深信服 AD 设备使用 DNAT 技术分发访问数据，此时的源 IP 为客户端 IP、目的 IP 为服务器 IP
4	服务器处理接收到的访问请求，并回复响应数据，此时的源 IP 为服务器 IP、目的 IP 为客户端 IP
5	深信服 AD 设备接收响应数据，转换源 IP 后再转发给客户端，此时的源 IP 为虚拟服务 IP、目的 IP 为客户端 IP

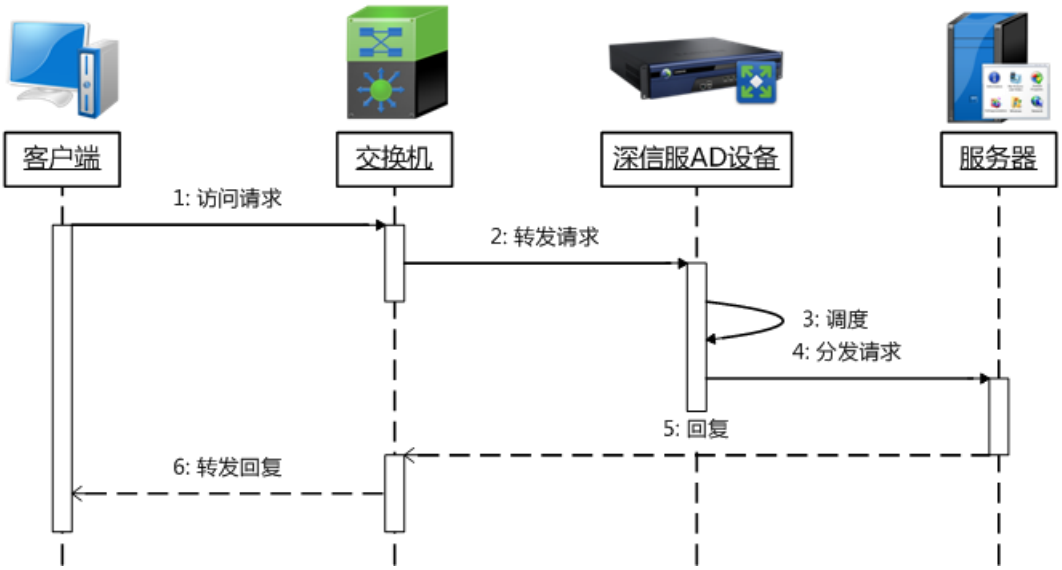
4.3.2 DR 方式 L4 服务器负载均衡

1. 实现方式

DR方式又称为三角传输模式，在该模式下实现服务器负载均衡，需要后台服务器在环回接口上配置虚拟服务 IP。AD 设备在分发访问请求时不改变目的 IP 地址，而是将目的 MAC 替换为服务器的 MAC 后，再将访问请求转发给后端的服务器，服务器的回复会直接通过交换机返回给用户。由于服务器的响应回复无需经过AD设备转发，从而减少了AD设备的吞吐压力，有效的避免了整个业务系统的性能瓶颈。

2. 工作流程

DR 方式 L4 服务器负载均衡的工作流程如下图所示



DR 方式 L4 服务器负载均衡的流程描述如下

步骤	说明
1	客户端发送服务访问请求，此时的源 IP 为客户端 IP、目的 IP 为虚拟服务 IP
2	交换机将访问请求转发给深信服 AD 设备
3	深信服 AD 设备接收到访问请求后，根据预先定义的负载均衡调度算法判断出应该将访问请求分发给哪台服务器
4	深信服 AD 设备向服务器分发访问数据，此时的源 IP 为客户端 IP、目的 IP 为虚拟服务 IP，目的 MAC 为服务器 MAC

5	服务器处理接收到的访问请求，并回复响应数据，此时的源 IP 为虚拟服务 IP、目的 IP 为客户端 IP
6	交换机接收响应数据，直接转发给客户端

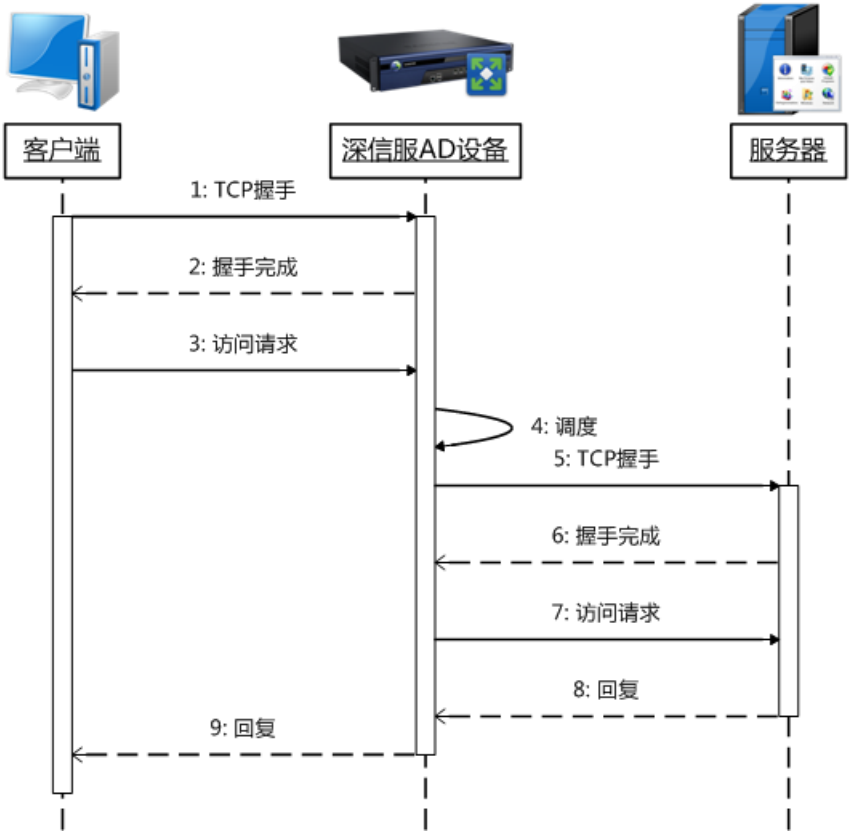
4.3.3 L7 服务器负载均衡

1. 实现方式

基于七层内容的调度机制，使得管理员可以通过应用层的内容交换来分配服务器资源，以实现用户请求调度的多元化和个性化，业务应用的场景十分广泛。例如，基于 URI、HOST、COOKIE、USER_AGENT 等 HTTP 头部内容的匹配策略来选择服务器，或者通过对 HTTP 头部进行请求改写和应答改写，执行页面跳转和丢弃等操作，实现不同业务系统之间的交互联动。在 L7 服务器负载均衡的场景中，AD 设备先与客户端建立 TCP 连接，获取到访问请求的报文之后，再根据报文中所带的应用层内容来选择合适的服务器并与之建立 TCP 连接，此时 AD 设备所扮演的角色类似于一台代理服务器。

2. 工作流程

L7 服务器负载均衡的工作流程如下图所示



L7 服务器负载均衡的流程描述如下

步骤	说明
1	客户端向深信服 AD 设备发起 TCP 连接请求，此时的源 IP 为客户端 IP、目的 IP 为虚拟服务 IP
2	客户端与深信服 AD 设备之间建立 TCP 连接
3	客户端发送服务访问请求，此时的源 IP 为客户端 IP、目的 IP 为虚拟服务 IP
4	深信服 AD 设备收到访问请求后，匹配虚拟服务调度策略，并负载均衡调度算法判断出应该将访问请求分发给哪台服务器，同时缓存该访问请求的数据
5	深信服 AD 设备向服务器发起 TCP 连接请求，其 SYN 序列号为客户端的 SYN 序列号，此时的源 IP 为客户端 IP、目的 IP 为服务器 IP
6	深信服 AD 设备与服务器之间建立 TCP 连接
7	深信服 AD 设备修改缓存的访问请求数据中的目的 IP 和 TCP 序列号，然后发送给服务器
8	服务器处理接收到的访问请求，并回复响应数据，此时的源 IP 为服务器 IP、目的 IP 为客户端 IP

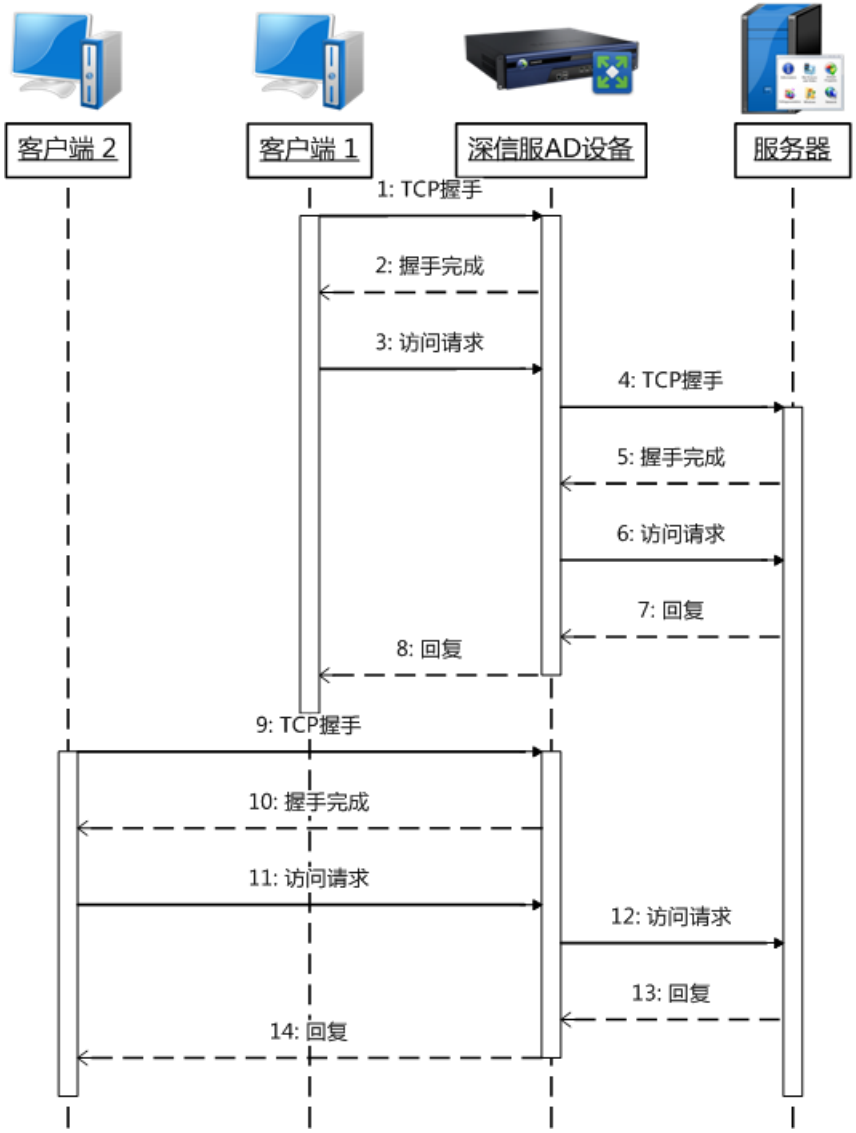
9	深信服 AD 设备修改响应数据的源 IP 和 TCP 序列号，然后转发给客户端，此时的源 IP 为虚拟服务 IP、目的 IP 为客户端 IP

4.4 服务器性能优化

信息化建设对各个组织机构而言都是一项长期的工作，硬件投资成本与性能回报是每个 IT 部门需要权衡的问题。有别于传统的负载均衡设备，深信服 AD 应用交付产品除了能实现服务器负载均衡机制，提高服务器资源的利用率之外，还支持 TCP 连接复用、内存缓存、HTTP 压缩、SSL 卸载等众多性能优化技术。通过减少服务器的硬件资源消耗，缩短服务器响应时间，在节省了硬件投资成本的同时，有效地保障用户访问的速度和稳定性，进而提升用户的访问体验。

4.4.1 TCP 连接复用

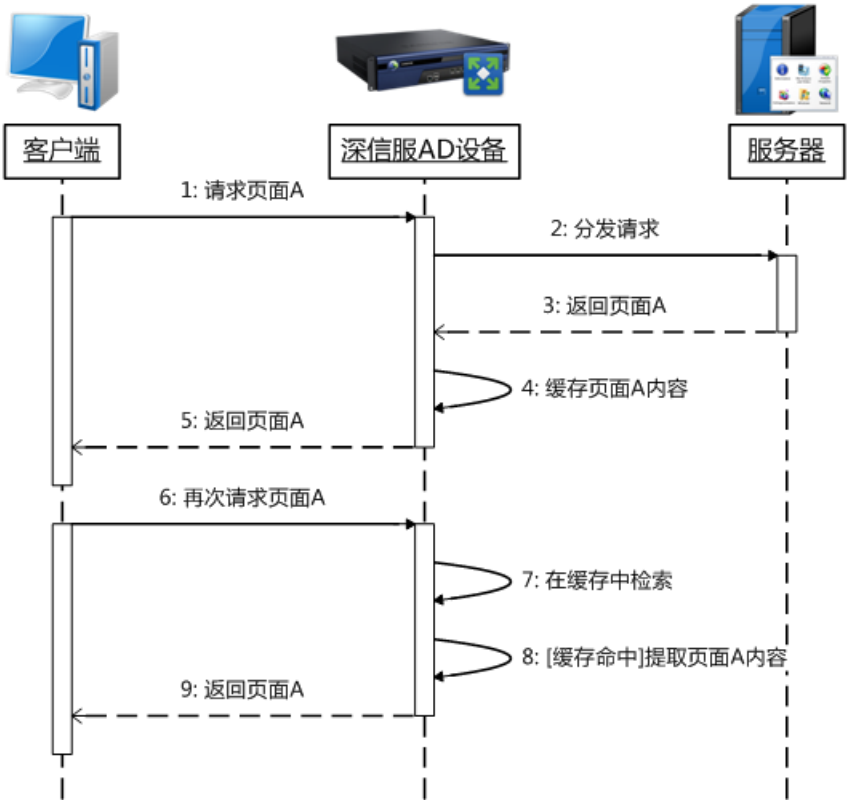
对于采用 HTTP 协议的应用系统，深信服 AD 设备可以将众多客户端访问请求捆绑处理，通过复用相对较少的服务器端 TCP 连接，将客户端请求依次转发到服务器，而不必通过一对一的方式将每一个客户端的 HTTP 请求通过专门建立的 TCP 连接转发到服务器。如此，在不需要改变任何网络构造也不需要增加组织的硬件投资成本的情况下，减少服务器的工作负荷，从而提高服务器的处理能力。



深信服 AD 设备保持先前用户访问时与后台服务器之间建立的 TCP 连接，以供后续访问使用，如此便显著减少了后台服务器需要处理的用户端连接数(减少量最高可以达到 90%)，加快了客户端与后台服务器之间的连接处理速度，提高应用系统的处理能力，节省组织的硬件投资成本。

4.4.2 内存缓存

深信服 AD 设备基于内存的反向代理 Cache 功能，在内存中缓存网站等相关资源的页面内容；采用内存缓存和包存储结构的方式，通过动态调整缓存空间提供远比其它缓存产品更快速的响应速度。

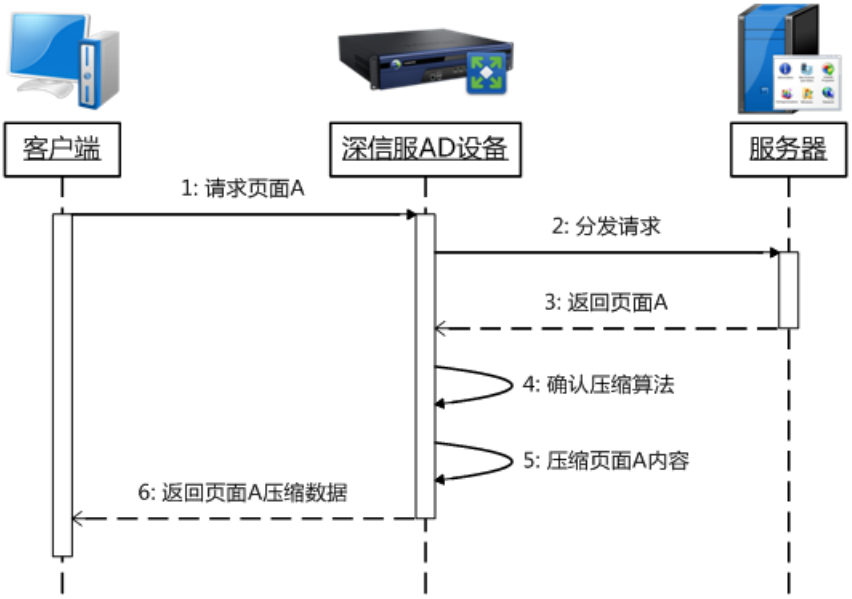


深信服 AD 设备缓存功能可降低用户访问对后台服务器的负载压力，在减少了后台服务器投资成本的同时，提高了系统的处理能力和用户的访问体验。

4.4.3 HTTP 压缩

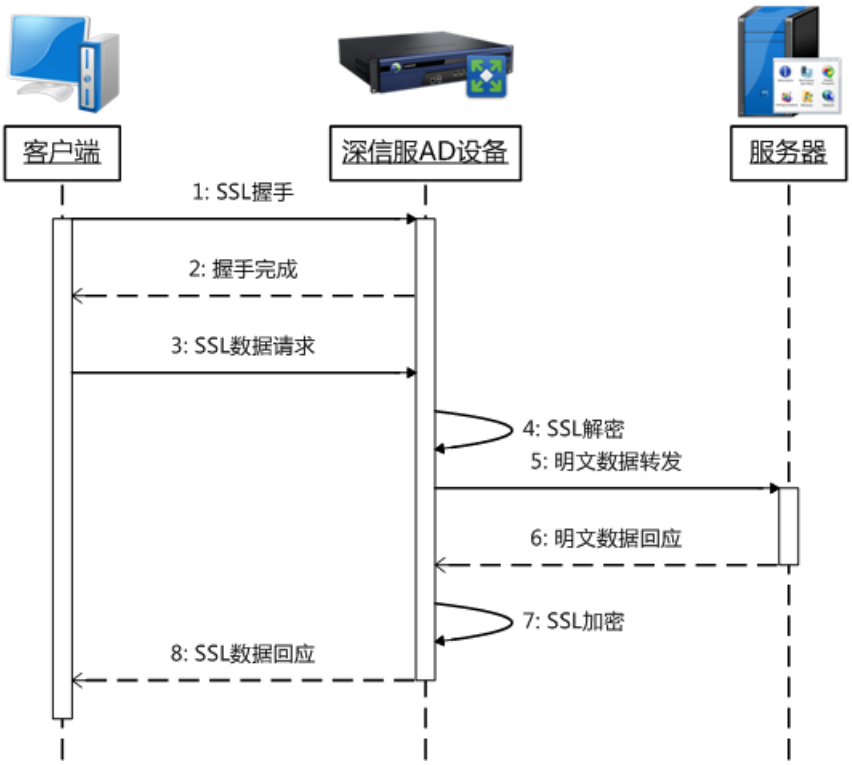
深信服 AD 设备的 HTTP 压缩功能，可通过标准的 HTTP 压缩规范自动识别客户端对 gzip 或 deflate 压缩算法的支持情况，并能够实现对数据动态压缩。

深信服 AD 设备的压缩功不仅能在最大程度上节省组织的互联网带宽，缩短用户下载内容的等待时间，更减轻了 Web 服务器的压力，节省硬件投资成本，提升用户的访问体验。



4.4.4 SSL 卸载

SSL 卸载技术是通过将应用访问过程中 SSL 的加解密过程转到深信服 AD 设备之上，从而减少服务器端的性能压力，提升客户端的访问响应速度。深信服 AD 设备具有强劲的 SSL 处理能力，不但能够实现端到端的 SSL 加密，同时支持全面的加密算法配置，并可管理服务器证书。



深信服 AD 设备通过对服务器的 SSL 卸载处理，在减少服务器性能消耗的同时，节省应用系统服务器数量，降低了业务系统的硬件投资，并大幅度缩短用户请求的响应时间从而极大提升了用户的访问体验。

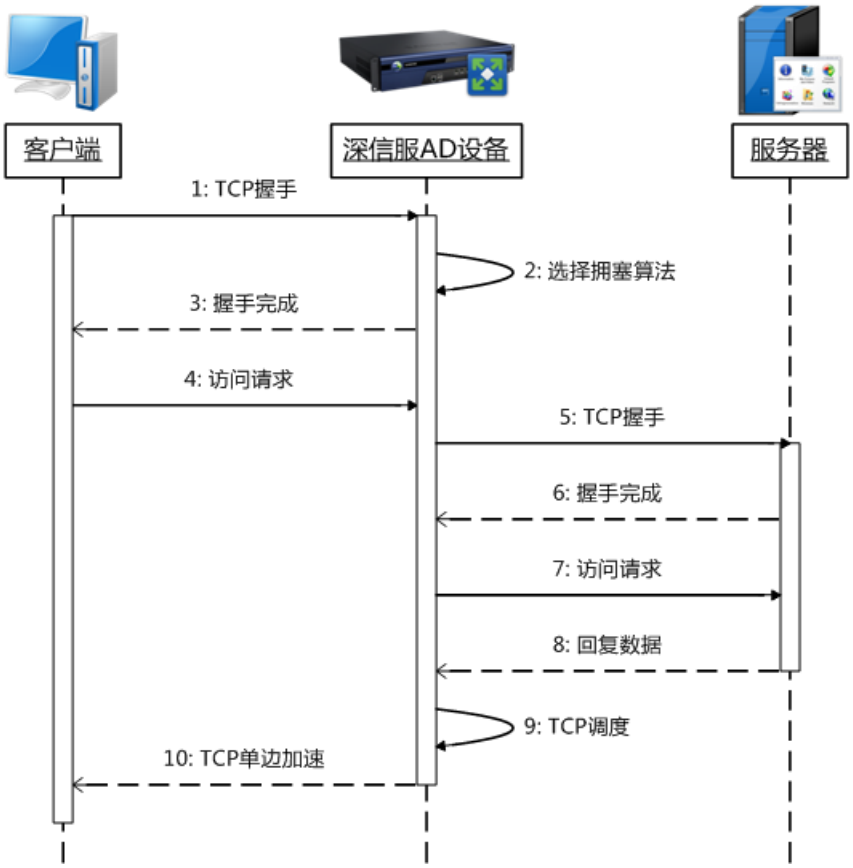
4.4.5 TCP 单边加速

单边加速的核心技术理念在于，通过自动、实时、持续、动态地侦测网络路径中的延迟、丢包、重传的情况，改变传出机制和改善传输拥塞机制，避免数据报文的过度重发，从而减少应用响应时间并提升 TCP 传输效率。由于是针对所有 TCP 数据流进行优化，因此不仅文件、电子邮件、网站等应用可以通过该技术实现加速效果，而且只要运行于 TCP 之上的应用，都可以通过深信服 AD 单边加速技术提升用户的访问体验。

传统 TCP 协议是基于局域网设计，一旦运用到互联网这种不稳定环境中的时候，就会使得数据的传输效率降低，特别在延时比较大、有丢包的时候尤为明显。单边加速技术通过对拥塞算法做优化处理，解决一些 TCP 协议本身的缺陷，以实现加速的效果；其核心部分是对拥塞算法做优化，如慢启动，拥塞避免，快速重传，快速恢复等。

- **拥塞避免 -** 能够快速的准确的预估出网络中可用带宽，并根据估计值确定拥塞避免窗口，从而最大限度的利用网络带宽。
- **快速重传 -** 允许接收端通过使用 SACK TCP 选项指示最多四个接收数据的非邻接块。RFC 2883 定义用于确认重复的数据包的 SACK TCP 选项中的字段的额外使用。发送端可以通过此操作确定何时重传了不必要的段并调整其行为，以防今后不必要的重传。发送的重传越少，整体吞吐量越合理。
- **快速恢复 -** 快速检测出丢包，并能快速准确重传该包，对时延较大，网络状况较差的情况能够有效的提升带宽利用率，通过更改快速恢复过程中发送端可以用来提高发送速率的方法，提供更大的吞吐量。
- **慢启动 -** 避免发送 TCP 对等方拥塞整个网络的现有算法被称为“慢启动”和“拥塞避免”。在连接最初发送数据和还原丢失段时，这些算法可以增大发送窗口，即发送端可以发送的段数量。对于每个接收到的确认段或每个已经确认的段，

“慢启动”算法会以一个完整的 TCP 段增大发送窗口。对于每个已经确认的完整窗口的数据，“拥塞避免”算法以一个完整的 TCP 段增大发送窗口。利用这些算法增大发送窗口的速度就足以充分利用连接带宽。



考虑到互联网的带宽是不断变化的，发送数据过快会导致数据拥塞，发送数据过慢会导致带宽利用率低，使网络速度减慢。单边加速技术也会实时根据网络延时调整发包频率，使发送数据量尽量接近实际网络带宽。而另一方面，标准 TCP 的算法在丢包的环境下重传数据过多，致使速度很慢。单边加速技术则会针对探测到的网络丢包现象，主动发送冗余数据，降低网络数据的重传率。

4.4.6 服务器弹性负载

面对愈加复杂的业务系统，主动探测式的服务器健康检查机制逐渐暴露出一定的局限性。尤其是在业务访问涉及到多层应用系统之间交互的情况下，当中途某个环节出了问题时，无法直接针对业务流程是否正常进行检测。此外，主动探测的方式对于未知协议、私

有协议的应用支持往往表现欠佳，无法对服务器的健康状况做出准确判断。针对传统方法的不足，深信服 AD 设备提供了一套基于服务器健康度的弹性调控机制，可通过监控业务流中的 TCP 传输异常来衡量服务器节点的有效性，尝试对性能不足的服务器临时开启过载保护，动态调节服务器的负载，进而保障整个业务系统的高可用性。

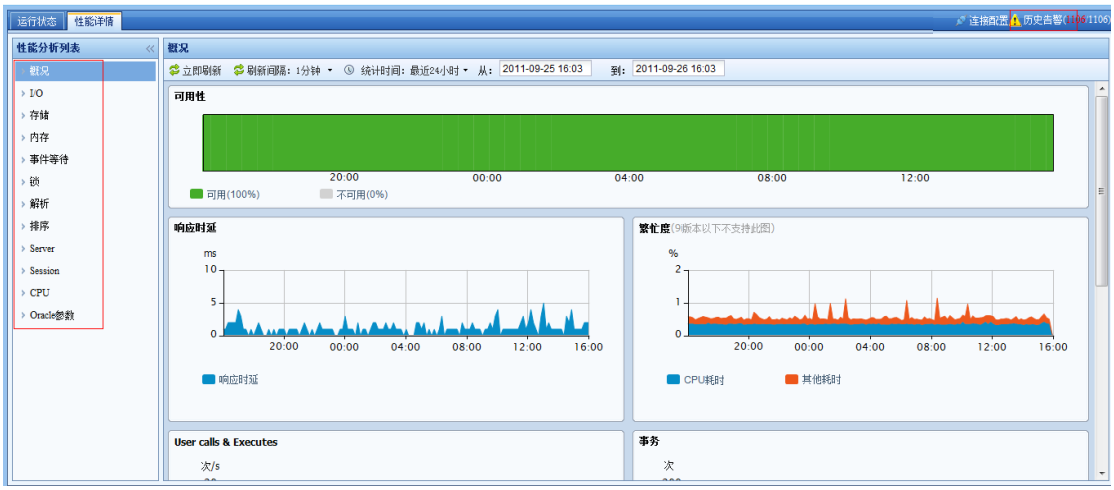
- **智能感知 -** 深信服 AD 通过持续观测业务流中的 TCP 传输行为来进行判断，当某服务器节点的状态满足失效条件时，即将该节点标记为无效，并不再向此节点转发来自客户端的请求
- **过载保护 -** 当判断为服务器性能不足时，深信服 AD 只对该服务器进行会话保持，而不进行任务分配，一段时间后再恢复调度，实现对服务器压力的弹性调控。

4.4.7 数据库中间件等后台应用组件深入分析

Oracle 数据库性能分析仅仅通过观察网络来定位系统问题，无法更确切地获知更深层次的原因，因为看不到除流量以外的信息。IT 管理者往往希望在出现性能问题的时候，能够定位到是网络问题、应用服务的问题还是后台数据库的问题，深信服 AD 还提供针对后台数据库的性能监控。

Oracle 版本	支持 Oracle 9i/ 10g/ 11g,Oracle RAC10g/11g 等版本无插件方式性能监控
监控优势	提供 Oracle 处理流程及关键性能指标的友好查看界面 可查看实时及历史信息 可以与数据库关联的硬件、应用、网络等信息联动，而非局限在数据库
性能指标	**包括**：数据库响应时间、当前总用户数、当前活跃用户数、繁忙度柱图、SQL*NET 接收速率、SQL*NET 发送速率、PGA 大小、PGA 使用、内存排序率、专用 Sever 数、共享 Sever 数、dispatcher 繁忙度、任务平均排队时间、redo 日志逻辑写速率、redo 日志物理写速率、SQL 执行速率、闪回日志写入速率、数据逻辑写速率、数据物理写速率、数据逻辑读速率、数据物理读速率、数据直接读速率、归档日志物理写速率、是否开启自动内存管理、SGA 大小、Redo Buffer 大小、Shared Pool

	大小、Buffer Cache 大小、Large Pool 大小、Java Pool 大小、Redo 写入成功率、SQL 解析命中率、缓存命中率、死锁数、LGWR/RVWR/DBWR/ARCH 进程、数据库大小、重做日志组、归档日志、数据库 IO 时延等



创新优势：深信服 AD 无需在用户数据库服务器上安装插件，不会对用户当前 IT 架构造成任何影响。通过 Oracle/RAC 自身的接口读取相关信息，无风险。用户只需提供一个查看数据库“系统视图”的普通管理员账号即可（例如 v$session,v$sysstat 这种视图的查询）。当添加正确的 Oracle 数据库后，系统即可自动识别 Oracle 版本及相关性能指标。

Weblogic 中间件性能分析 Weblogic Server 支持包括 EJB、JSB、JMS、JDBC、XML和WML在内的业内多种标准，使Web应用系统的实施更为简单，并且保护了投资，同时也使基于标准的解决方案的开发更加简便。用户除了希望针对WEB做深入解码分析，还希望获知 Weblogic 的工作状况，深信服 AD 提供 Weblogic 性能监控。

Weblogic 版本	支持 Weblogic9.0/9.1/9.2/10.0/10.3/11g(10.3.1)等版本无插件性能监控
监控优势	提供 Weblogic 处理流程及关键性能指标的友好查看界面 可查看实时及历史信息 可以与数据库关联的硬件、应用、网络等信息联动，而非局限在数据库
性能指标	**包括**：weblogic 可用性、响应延迟等状态信息、JVM 信息、线程池使用、执行队列列表、等待处理的请求数、JDBC 信息、WEB 应用列表、会话数、Servlet 、EJB 应用缓存命中趋势、池的使用率、Bean 列表、JTA 活动处理数、时间、次数、JMS 消息数、等待消息趋势、server 详情等

创新优势：深信服 AD 无需在用户 Weblogic Server 上安装插件，不会对用户当前 IT 架构造成任何影响。通过 Weblogic 自身的接口读取相关信息，无风险。用户只需提供一个拥有 monitor 权限的用户账号即可。当添加正确的 Weblogic Server 后，系统即可自动识别 Weblogic 版本及相关性能指标。

4.4.8 被动漏洞扫描

相比主动漏洞扫描工具或者是市场的漏扫设备，被动漏洞分析最大的优势就在于能实时发现客户网络环境的安全缺陷，且不会给网络产生额外的流量。此模块设计的初衷就是希望能够实时发现和跟踪网络中存在的主机、服务和应用，发现服务器软件的漏洞，实时

分析用户网络中存在的安全问题，为用户展现 AD 的安全防护能力。实时漏洞分析功能主要可以帮助用户从以下几个方面来被动的对经过的流量进行分析：

WEB 漏洞分析

实时分析网络流量，发现网络中存在漏洞的应用，把漏洞的危害和解决方法通过日志和报表进行展示，支持的应用包括：HTTP 服务器(Apache、IIS) 。

Web 应用风险分析

针对用户 WEB 应用系统中存在的如下风险和安全问题进行分析：

1.SQL 注入、文件包含、命令执行、文件上传、XSS 攻击、目录穿越、webshell；

2.发现网站/OA 存在的设计问题，包括：

a)在 HTTP 请求中直接传 SQL 语句；

b)在 HTTP 请求中直接传 javascript 代码；

c) URL 包含敏感信息：如 user、username、pass、password、session、jsessionid、sessionid 等；

Web 不安全配置检测

各种应用服务的默认配置存在安全隐患，容易被黑客利用，例如，SQL Server 的默认安装，就具有用户名为 sa，密码为空的管理员帐号。不安全的默认配置，管理员通常难以发觉，并且，随着服务的增多，发现这些不安全的配置就更耗人力。

AD 支持常用 Web 服务器不安全配置检测，如 Apache 的 httpd.conf 配置文件，IIS 的 metabase.xml 配置文件，nginx 的 web.xml 和 nginx.conf 配置文件，Tomcat 的 server.xml 配置文件，PHP 的 php.ini 配置文件等等，同时也支持操作系统和数据库配置文件的不安全配置检测，如 Windows 的 ini 文件，Mysql 的 my.ini，Oracle 的 sqlnet.ora 等等。

弱口令检测

支持 FTP，POP3，SMTP，Telnet，Web，Mysql，LDAP，AD 域等协议或应用的弱口令检查。

设备对弱口令的定义如下：

空口令

用户名和密码相同

a.长度小于等于 8 位的纯数字

b.长度小于等于 8 位的纯字母

c.长度小于等于 8 位的字典序

d.长度小于等于 6 位仅数字和字母

五、 关于深信服

深信服公司成立于 2000 年，是中国最大的应用层网络设备供应商，致力于提供基于网络应用层的产品及解决方案。目前，全球有超过 21,000 家用户正在使用深信服的产品。在中国入选世界 500 强的企业中，有 85%以上的企业都是深信服的用户。截止 2013 年 3 月，深信服在全球共设有 49 个直属分支机构，分布在全球 8 个国家和地区，并拥有超过 1400 名员工。

作为中国应用层网络市场的领导者，深信服每年保持着 50%以上的增长率，持续每年将总营收的 15%投入到研发，并在深圳和北京设有研发中心。截至 2013 年 3 月，深信服共申请超过 100 项发明专利。同时，深信服还是 IPSec VPN 和 SSL VPN 两项国家标准的主要承建单位。

深信服公司被评定为“国家规划布局内重点软件企业”，连续八年入选德勤“亚太地区高科技高成长 500 强”，连续两届荣获《财富》“卓越雇主——中国最适宜工作的公司”。